

## Seminar Preparation

(Evidence: <https://www.my-course.co.uk/mod/forum/discuss.php?d=368281#p742939>)

*Q1: Key elements and interdependencies in a comprehensive ICPS threat model*

### The four core elements Jbair et al. (2022) identify:

- **Assets** – classified by Purdue Model level; lower levels (PLC, sensors) have higher criticality because they interact directly with the physical process
- **Threat actors** – characterised by skills, resources, and motivation; both insider and outsider profiles must be included
- **Vulnerabilities** – weaknesses that threat actors can exploit; sourced from CVE databases, vendor advisories, and ICS-CERT
- **Attack impacts** – assessed across confidentiality, integrity, availability, and safety (CIAS rather than the standard CIA triad)

### Why the interdependencies matter:

- A threat actor's skill level determines which vulnerabilities are reachable
- The reachable vulnerabilities determine which Purdue levels are exposed
- Purdue level determines impact magnitude, so the risk is a product of the whole chain, not any single element
- Example from the paper: compromising the OPC UA server (Level 3) opens lateral movement paths to the Level 1 PLC – assessing either asset in isolation understates the risk

### What happens if you miss an element:

- No threat actor profiling: you cannot calibrate likelihood or prioritise by realistic capability
- No asset hierarchy: all assets are treated equally, which wastes control budget on low-criticality assets
- No interdependency mapping: single-point mitigations leave chained attack paths open

### Frameworks used to capture these elements:

- Purdue Model for asset hierarchy
- ICS ATT&CK for adversary TTPs
- STRIDE for systematic threat classification per component
- Neither ATT&CK nor STRIDE alone is sufficient – ATT&CK without STRIDE misses unanticipated threat categories; STRIDE without ATT&CK lacks grounding in real adversary behaviour (SEI, 2018)

*Q2: How threat modelling identifies attack entry points and vulnerabilities – and the challenges*

### How it identifies entry points:

- System decomposition first: list all assets, data flows, and trust boundaries
- Attack trees then trace adversary paths from initial access to target objective
- Example from the paper (Festo PLC firmware attack): Network Scan (T841) → Connection Enumeration (T840) → Port Identification (T885) → Valid Account exploitation (T859) → firmware modification
- Key insight: the entry point is a network exposure, not the firmware itself – a patching strategy alone would leave the entry path open

#### **How ICS ATT&CK specifically helps:**

- Maps each step in the attack tree to observed real-world techniques
- Grounds the model in documented adversary behaviour rather than theoretical threats
- Allows analysts to check detection coverage: if a technique appears in ATT&CK, detection mechanisms should exist

#### **Challenges in doing this effectively:**

##### Technical challenges:

- Legacy OT protocols often have no native authentication, so standard IT controls do not apply directly
- Long asset lifecycles mean vulnerabilities may be known but unpatched for years
- Safety instrumented systems may impose uptime requirements that conflict with compensating controls

##### Methodological challenges:

- Attack tree completeness cannot be proven – the tree is only as good as the analyst's knowledge of the system and the adversary (Shostack, 2014)
- In a complex energy ICPS with heterogeneous vendor components, full coverage without tooling support is practically impossible
- Jbair et al. (2022) acknowledge their own framework does not cover insider threats or supply chain attack paths

##### Standards gap:

- ISA/IEC 62443 provides an OT security baseline but requires significant mapping work to apply to a specific asset configuration
- NIST SP 800-82 offers ICS-specific guidance but does not prescribe a threat modelling method

#### *Q3: Scenario-specific metrics and prioritisation for targeted countermeasures*

#### **The Jbair et al. (2022) hybrid approach:**

- Quantitative: Attack Vector (AV) score = geometric mean of threat actor capability, threat exposure, and threat impact
- Qualitative: Attack Likelihood (AL) score based on historical sector incident data
- Risk score = AV × AL, plotted on a heat map with five severity bands

### **Why a composite metric produces better prioritisation than a single score:**

- Prevents any one dimension (e.g. asset criticality) from dominating the rating
- Example from the paper: PLC Code Changes scores risk rating 16 (high actor skill + high likelihood); PLC Denial of Service scores only 4 despite the PLC being the most critical asset – because DoS requires fewer resources and has lower documented likelihood in the automotive sector
- A programme that treated all PLC threats equally would over-invest in DoS countermeasures at the expense of code-change controls

### **How metrics guide countermeasure selection:**

- High AV + high AL → immediate technical control (firmware monitoring, code-change monitoring)
- Low AV + low AL → management control sufficient (password policy enforcement)
- Controls are generated automatically from the digital twin metadata in the Jbair et al. methodology, reducing implementation lag

### **Critical limitations to raise in discussion:**

- **Likelihood data quality:** attack likelihood scores are backward-looking (based on APT32/APT37 historical campaigns); they may not reflect emerging threat actors – Aven and Thekdi (2025) argue all risk scores should be accompanied by explicit strength-of-knowledge judgements
- **Ordinal multiplication:** multiplying ranked scores to produce a risk number inherits Cox's (2008) critique – the resulting rankings can be misleading when input scales are ordinal rather than cardinal
- **No distributional output:** a FAIR-based approach (Open Group, 2021) would express the same risk as a probability distribution, producing statements such as "10% chance annual loss exceeds £X" – more useful for investment decisions than a point score
- **The authors themselves flag:** financial loss prediction and insider threat analysis are identified as future work, meaning the framework as published is incomplete for full business-case justification

### **A strong seminar point to make:**

- The value of Jbair et al. (2022) is not the metrics themselves but the structured process that forces analysts to justify every score against documented criteria – this discipline reduces the subjectivity that makes risk matrices unreliable in practice

### **Quick reference citations:**

- Jbair et al. (2022) – Computers in Industry, 137, p.103611
- Shostack (2014) – Threat Modeling: Designing for Security, Wiley
- SEI (2018) – Threat Modeling: A Summary of Available Methods, CMU
- Aven and Thekdi (2025) – Risk Science: An Introduction, Routledge
- Open Group (2021) – Risk Analysis (O-RA) v2.0.1
- Cox (2008) – 'What's wrong with risk matrices?', Risk Analysis, 28(2)